SAVEETHA

INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

192311199
K Sujith

Course Code: **CSA63**

Course Name: **Threat Intelligence and Network Security**

Duration: **1: 30 Hr** ·

Date :

Max Marks:
50 Marks

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes

On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.
CO2	Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Answer all the Questions

1. Medilife Hospital runs a patient-records portal that doctors, nurses and insurers access over the hospital network. In one week the security team logs three incidents: (i) ransomware encrypts the radiology database and staff cannot open scans, (ii) a disgruntled employee silently changes a patient's blood-group entry in the lab system, and (iii) an attacker captures unencrypted patient data travelling on the Wi-Fi network without altering it. Interpret each incident against the CIA triad, identifying the security goal that is primarily violated and justifying your choice. Classify each incident as a passive or active threat and as an internal or external threat. Recommend one preventive control for each incident, explaining how it restores the violated goal. Then analyse how the three goals can conflict with one another when the hospital designs access to emergency

patient records, and explain why a balance among confidentiality, integrity and availability is required for a hospital network.

(10) (CO1) (BL3)

2. The Security Operations Centre (SOC) of a national bank receives four intelligence items in a single morning: (i) a quarterly report from a consulting firm stating that financially motivated groups are expected to target mobile-banking customers over the next year, (ii) a list of malicious IP addresses and domain names linked to a phishing campaign, (iii) an advisory describing the attacker's planned timing, tools and likely targets for an imminent attack on the bank's payment gateway, and (iv) a write-up of the attacker's tactics, techniques and procedures (TTPs) in a recent banking-malware campaign. Classify each item as strategic, tactical or operational threat intelligence, justifying your choice. Compare the three types of threat intelligence in terms of
(a) target audience and decision level,
(b) time horizon and level of technical detail, and
(c) typical sources and the action taken by the bank.

   Finally, analyse what the bank would lose if it relied only on tactical intelligence (IoC lists) and ignored strategic and operational intelligence.

   (10) (CO1) (BL4)

3. a) An e-commerce company wants to build a threat intelligence programme after a data breach. Apply the threat intelligence lifecycle to the company by describing, for each phase (direction/planning, collection, processing, analysis, dissemination and feedback), the activities carried out and the output produced. Explain how the feedback phase keeps the lifecycle continuous, and give two applications of threat intelligence in the IT industry (such as SOC operations, incident response or vulnerability prioritisation) that the company can adopt.

   (5) (CO1) (BL4)

   b) An employee in the finance department receives an email that appears to come from the CEO, urging an immediate payment and containing a link to a "secure invoice portal". The employee clicks the link, enters credentials and downloads an attachment, after which files on the shared drive become inaccessible. Analyse the incident by identifying the types of attack involved (phishing and malware), the stages of the attack from email delivery to impact, and the indicators in the email that should have raised suspicion. Suggest two technical and two user-awareness measures to prevent a recurrence.

   (5) (CO2) (BL4)

4. A university campus network experiences three problems: (i) the online examination portal becomes unreachable when thousands of requests per second arrive from many compromised devices around the world, (ii) students connected to the free campus Wi-Fi are redirected to a fake login page, and their traffic is relayed through an attacker's laptop that reads and modifies the data, and (iii) an attacker sends packets with a forged source address of the registrar's server to gain access to the administrative VLAN, while another user runs a packet-capture tool to read unencrypted traffic. Identify the attack in each case and explain how it works. Distinguish between DoS and DDoS attacks, between spoofing and sniffing, and between sniffing (passive) and a man-in-the-middle

attack (active). For each attack, describe one detection technique and two countermeasures (for example, rate limiting and traffic scrubbing, HTTPS/TLS with certificate validation, ARP inspection, encryption and ingress filtering) that the university should deploy. Also explain how a vulnerability assessment of the campus network would help reduce the likelihood of these attacks.

(10) (CO2) (BL4)

5. A threat-intelligence analyst at a managed security provider receives a commercial threat feed containing the following entries related to a ransomware campaign: IP address 203.0.113.45, domain "secure-login-update[.]com", file hash (SHA-256) of a malicious dropper, URL "hxxp://secure-login-update[.]com/invoice.exe", and the email subject line "Urgent: Invoice Overdue". The provider also wants to supplement the feed with open-source intelligence (OSINT). Analyse the feed by classifying each entry as a network, host or email indicator of compromise (IoC) and evaluating which entries are easy or hard for an attacker to change. Explain how the analyst should assess the quality of the feed (timeliness, accuracy, relevance and context) before deploying the IoCs to firewalls and SIEM tools, and the risk of false positives. Identify four OSINT sources and the data collection techniques (such as monitoring social media, paste sites, public breach databases, domain WHOIS and passive DNS) that can enrich the feed, and compare OSINT with commercial threat feeds in terms of cost, reliability and coverage. Finally, justify which combination of sources the provider should use.

(10) (CO2) (BL4)

04-11-26

Threat Intelligence & Network Security. CIA-1

K. Sujith Sai Vighnesh
192311199
CSA6303

1) CIA Triad - Security Incidents in Medilife Hospital

Ans The CIA Triad is a fundamental model of Information Security.

It consists of three main principles:

* Confidentiality
* Integrity
* Availability

42

A. Analysis of three incidents:

1. Ransomware Encrypting the radiology database.

- Security goal : Availability
- Threat classification : Active & external threat.
- Explanation : Ransomware is malicious software that encrypts hospital file & prevent doctors from accessing patient scans
- Preventive control : Regular offline backups & endpoint protection.

* Backup helps to allow hospital to restore the encrypted records.

2. Employee changing a patients blood-group entry:

- Security goal : Integrity
- Threat classification : Active & Internal threat
- Explanation : A disgruntled employee intentionally modifies medical information without authorization
- Preventive control : Role Based Access control [RBAC] & Audit logs.
- How it helps : Only authorized personal can modify medical records.

3. Attacker Capturing Unencrypted Patient data over wifi:

- Security goal : Confidentiality
- Threat classification : Passive & external threat
- Explanation : The attacker intercepts patient information travelling through the wifi network without changing the original data.
- Preventive control : WPA3 encryption & HTTPS/TLS

* Encryption converts readable information into an unreadable format, Preventing attackers from understanding intercepted data.

B. Conflit between CIA Triad Principles

In a hospital, all three security goals are important, but sometimes they conflit.

Example - Emergency patient records

⇒ When a patient ~~cover~~ arrives in an emergency, doctors must immediately access medical records.

- Confidentiality : Only authorized doctors should access patient medical records
- Integrity : Medical records must maintain accuriate & shouldn't be modified by unauthorized access
- Availability : Doctors must access records immediately during emergencies.

Solution => The hospitals should implement

- Role based access control
- Multifactor Authentication where appropriate
- Encryption of Patient records

Conclusion :

The CIA Triad protects hospital information from unauthorized access, modification & disruption. A proper balance between confidentiality, integrity & availability is essential to protect patient information & provide uninterrupted medical services.

2. Types Of Threat Intelligence :

Ans Threat Intelligence is the process of collecting, analysing & sharing information about cyber threats to help organizations identify & prevent attacks. There are three main types of threat intelligence-

1. Statergic Threat Intelligence
2. Tactical Threat Intelligence
3. Operational Threat Intelligence

A. Classification of the Four intelligence items :

Intelligence Item	Type	Justification
Quarterly Report Predicting future attacks	Statergic	Provides long term threat & business risk.
Malicious IP attack & Domain	Tactical	Provides technical indicators used to detect attacks
Advisory about imminent attack	operational	Gives details about a specific upcoming attack
Attacker's TTP's	Tactical	Explains the techniques & method used by attackers

Limitations of using only Tactical intelligence :

- Misses long-term cyber threats.
- Fails to understand attacker objectives.
- Cannot prepare properly for upcoming attacks.

- May miss new attacks using modified techniques

Comparision :

Basis	Statergies	Tactical	Operational
Audience	Management	SOC teams	Incident Response Attacks
Decision	Long - Term	Technical	Immediate
Time	Long - Term	Medium term	Short - term
Detail	Low	High	High
Sources	Industry Reports	Security Research	Threat feeds & incident
Action	Security Planning	Improve Detection	Respond to attacks.

C. Risk of relying only on tactical intelligence.

- If the bank relies only on tactical intelligence such as IP address & domain lists. it may face the following problems.

* Lack of Planning
* Limited attack understanding attackers objectives & methods.
* Missed attacks to avoid detection.
* Delayed Response.
* Poor Security decisions - management cannot properly Prioritize security investments.

Conclusion :

A Bank Should combine Statergic tactical & operational intelligence to understand threats, improve security systems and respond effectively to cyber attacks.

3. a) Threat Intelligence Lifecycle in an E-commerce company :

The threat intelligence lifecycle is a continous process of collecting, processing and analysing threat information to support cyber security decisions.

Phases of threat intelligence lifecycle :

1. Direction / Planning :

→ Identify the company's security objectives & requirements
- Decide what threat information is required.

2. Collection :

→ Collect information, gathes data from logs, firewalls & threat feeds.

3. Processing :

Filter organize & remove duplicate information

4. Analysis :

Identify attack patterns & security risks.

5. Dissemination :

Share the findings with SOC and the IT teams

6. Feedback :

collect feedback & improve intelligence activities.

Conclusion : The lifecycle helps organisations detects

threats early & improve security.

b] Phishing & Malware Attack :

The attacker impersonates the CEO to steal credentials and deliver malware.

Types of Attacks :

* Phishing :- Fake emails tricks employees into revealing Credentials.
* Malware :- Malicious Attachment injects the system & makes the shared file in accessible.

Attack Stages :

→ Attackers sends a fake CEO email.
→ Employee clicks the suspecious link.
→ Employee enters login credentials.
→ Employee downloads a malicious attachment
→ Malware injects the system
→ Shared drive files becomes in accessible.

Suspecious Indicators :

→ Urgent payment requests
→ Unknown sender address
→ Suspecious links & Requests for login credentials.
→ Unexpected email attachments

Prevention Measures :

→ Email Security Gateway
→ End Point Detection & Response [EDR]

Conclusion : Combining email security, EDR helps preventing phishing & Malware Attacks

4) Cyber Attacks on University Network :

Ans Identification of Attacks :

i) Examination Portal becomes Unavailable :-

Attack : DDOS

→ Multiple compromised devices send excessive requests, overwhelming servers

ii) Fake Campus wifi login page.

Attack : Evil Twin & Man in Middle.

→ Attacker creates fake wifi & intercepts or modifies student data.

iii) Forged register IP & Packet capture :

IP spoofing : Attacker satisfies the source IP address to impersonate a trusted server.

→ Attacker captures network packets to read unencrypted information.

Role of Vulnerability Assessment :

1) Identifies Outdated Software
2) Detects weak wifi - Security
3) Finds open ports & insecure services
4) Identifies network configuration weakness

DOS vs DDOS

DOS	DDOS
Attack from one source	Attack from multiple sources
Easier to Detect	Difficult to detect
Comparatively less traffic	Very High traffic
Easier to Block	Requires traffic filtering

Spoofing vs Sniffing :

Spoofing	Sniffing
Fakes the identity or IP address	Captures network Packets
Can be Active	Usually passive
Ex : IP spoofing	Ex : Password Interception.

Sniffing vs MITM :

Sniffing	MITM
Passive Attack	Active Attack
Only Reads the traffic.	Reads & modifies traffic.
Does not Alter communication	Can change communication.

Conclusion :

→ Encryption, traffic filtering, Secure Authentication & Vulnerability assessment protects the University network.

5] Threat Intelligence Feeds & OSINT

→ Threat Intelligence feeds provide information about cyber threats such as IP addresses domains URL's & file hashes.

Classification Of IOC's :

Entry	IOC Type	Change difficulty
IP Address	Network	Easy
Malicious Domain	Network	Moderate
SHA-256 Hash	Host	Difficulty without modifying file
Malicious URL	Network	Very easy

5)

Function

=> Function is a ~~block that contains~~ block of code that contain a set

Threat feed Quality Assessments :

* Timeliness
* Accuracy
* Relevance
* Context

OSINT vs commercial Threat feeds :

Basis	OSINT	commercial feeds
Cost	Mostly free	Paid
Reliability	Varies	Generally validated
Coverage	Broad Public data	curated threat data.
Updates	May be irregular	Regular updates
Support	Limited	Vendor support.

Recommended Combinations :

The provide should combine

- Commercial feeds for verified malicious indicators.
- Social media & forums for emerging threats
- Breach Databases for exposed credentials
- Whois & Passive DNS for Domain investigation.